

BAN CƠ YẾU CHÍNH PHỦ
HỌC VIỆN KỸ THUẬT MẬT MÃ



ĐỀ CƯƠNG CHUYÊN ĐỀ CƠ SỞ
**XÂY DỰNG HỆ THỐNG NGĂN CHẶN RANSOMWARE TẠI KERNEL-
SPACE VÀ PHỤC HỒI DỮ LIỆU**

Khoa: An toàn thông tin

Sinh viên thực hiện:

Phạm Xuân Hòa – AT200222

Nguyễn Đình Huy Dũng – AT200214

Trần Tuấn Ngọc – AT200242

Người hướng dẫn:

TS. Lê Anh Tiến

Khoa công nghệ thông tin – Học viện Kỹ thuật mật mã

Hà Nội - 2026

I. MỞ ĐẦU

1. Tính cấp thiết của đề tài

Trong bối cảnh an toàn không gian mạng hiện nay, Ransomware (mã độc tống tiền) đã trở thành một trong những mối đe dọa nghiêm trọng nhất đối với cả cá nhân và tổ chức. Các dòng mã độc hiện đại không ngừng tiến hóa, sử dụng các kỹ thuật lẫn khuất tinh vi (như Fileless, Obfuscation) và lạm dụng quyền hợp lệ để qua mặt các hệ thống Antivirus (AV) dựa trên chữ ký truyền thống.

Bên cạnh đó, các giải pháp giám sát hành vi tại tầng ứng dụng (User-space) đang bộc lộ nhiều điểm yếu, dễ dàng bị mã độc vô hiệu hóa (Unhooking) hoặc chịu độ trễ dẫn đến việc mất mát dữ liệu trước khi kịp ngăn chặn. Chính vì những thách thức này, việc nghiên cứu và chuyển đổi mô hình phòng thủ xuống tầng lõi hệ điều hành (Kernel-space) kết hợp với công nghệ đánh lừa (Deception Technology/Canary Files) trở nên vô cùng cấp thiết. Hệ thống này sẽ cung cấp đặc quyền sinh sát cao nhất, giúp chặn đứng luồng ghi đĩa bất hợp pháp ngay lập tức và bảo vệ tính toàn vẹn của dữ liệu.

2. Mục tiêu nghiên cứu của đề tài

Sử dụng các kỹ thuật dịch ngược, lập trình hệ thống bằng C/C++ với Windows Driver Kit (WDK) và ngôn ngữ Python để xây dựng một hệ thống phát hiện, ngăn chặn và khắc phục sự cố Ransomware toàn diện. Các mục tiêu cụ thể:

- Dịch ngược và bóc tách thành công luồng thực thi, thuật toán mã hóa của một mẫu Ransomware.
- Xây dựng Kernel Minifilter Driver để giám sát và ngăn chặn các lời gọi hệ thống (System Calls) độc hại.
- Áp dụng thuật toán Shannon Entropy để tính toán độ hỗn loạn dữ liệu theo thời gian thực.
- Xây dựng công cụ giải mã (Decrypter) để khôi phục dữ liệu dựa trên các điểm yếu của thuật toán sinh khóa.

3. Đối tượng và phạm vi nghiên cứu

- Đối tượng nghiên cứu:
 - Phần mềm: Mẫu mã độc Ransomware (WannaScream), công cụ dnSpy.
 - Hệ thống: Cơ chế quản lý File System I/O của Windows, kiến trúc Minifilter Driver.
- Phạm vi nghiên cứu:
 - Hệ điều hành Windows 10/11 (64-bit) trong môi trường ảo hóa.

- Quá trình giám sát tập trung vào sự kiện ghi file (IRP_MJ_WRITE) và đổi tên file (IRP_MJ_SET_INFORMATION) cục bộ.

4. Các nhiệm vụ chính cần thực hiện

Nội dung nghiên cứu được tập trung vào các nội dung chính như sau:

- Thiết lập môi trường Lab cô lập an toàn để phân tích mã độc
- Nghiên cứu sử dụng dnSpy để dịch ngược mã thực thi, tìm hiểu Windows API và trích xuất điểm yếu sinh khóa.
- Nghiên cứu kiến trúc WDK, phát triển File System Minifilter Driver bắt sự kiện cấp Kernel.
- Nghiên cứu sử dụng kỹ thuật Canary Files và thuật toán Shannon Entropy để làm cơ sở định danh hành vi mã hóa.
- Nghiên cứu và code công cụ Decrypter để tự động hóa quá trình giải mã khôi phục dữ liệu.

5. Kết quả dự kiến

- **Lý thuyết:**
 - Hiểu rõ vòng đời hoạt động, kỹ thuật lẩn tránh của Ransomware và cơ chế hoạt động của I/O Manager trong Windows Kernel.
 - Nắm vững nguyên lý của công nghệ Deception và thuật toán đo lường dữ liệu Entropy.

- **Thực nghiệm:**

Hệ thống hoàn chỉnh gồm 2 module chính với các chức năng:

- **Module Phòng thủ (Kernel Driver & Service):** Nhận diện chính xác 100% khi file mới bị can thiệp; đo lường Entropy trả về kết quả cấu trúc tệp bị phá vỡ; block thành công lệnh ghi đè và cô lập tiến trình độc hại, bảo vệ an toàn các tệp tin hệ thống.
- **Module Khôi phục (Decrypter):** Trích xuất key thành công và giải mã khôi phục lại nguyên vẹn các file mới đã bị mã hóa trước khi tiến trình bị ngắt.

II. DỰ KIẾN CÁC CHƯƠNG MỤC THỰC HIỆN

MỤC LỤC

LỜI CẢM ƠN

LỜI NÓI ĐẦU

DANH MỤC KÝ HIỆU VÀ CHỮ VIẾT TẮT

DANH MỤC HÌNH VẼ

CHƯƠNG 1. TỔNG QUAN VÀ PHÂN TÍCH MÃ ĐỘC RANSOMWARE

1.1. Tổng quan về Ransomware và các thách thức phòng thủ

1.1.1. Khái niệm, vòng đời tấn công và sự tiến hóa của các dòng Ransomware hiện đại.

1.1.2. Hạn chế của giải pháp phòng thủ tại User-space trước kỹ thuật lẩn tránh (Unhooking, Fileless).

1.1.3. Lợi thế của kiến trúc Kernel-space và mô hình File System Minifilter Driver.

1.1.4. Công nghệ đánh lừa (Deception Technology) và vai trò của tập tin mồi nhử (Canary Files).

1.2. Phân tích và Dịch ngược mã độc thực nghiệm

1.2.1. Thiết lập môi trường Lab cô lập và quy trình phân tích mã độc an toàn.

1.2.2. Phân tích tĩnh với dnSpy: Trích xuất Windows API, định vị luồng thực thi và xác định thuật toán mã hóa.

1.2.3. Phân tích động: Theo dõi hành vi duyệt thư mục và xác định cơ chế sinh khóa (Key Generation) của mã độc.

CHƯƠNG 2: XÂY DỰNG HỆ THỐNG NGĂN CHẶN TẠI KERNEL-SPACE

2.1. Kiến trúc hệ thống phòng thủ chủ động

2.1.1. Sơ đồ giao tiếp giữa Kernel-mode Driver (.sys) và User-mode Service qua Communication Port.

2.1.2. Cơ chế triển khai và giám sát tập tin mồi nhử tại I/O Manager.

2.2. Phát triển File System Minifilter Driver

2.2.1. Đăng ký và xử lý Callback cho các sự kiện IRP_MJ_WRITE và IRP_MJ_SET_INFORMATION.

2.2.2. Thuật toán tính toán Shannon Entropy để định danh hành vi mã hóa dữ liệu theo thời gian thực.

2.2.3. Cơ chế ngăn chặn: Trả về lệnh STATUS_ACCESS_DENIED để bảo vệ dữ liệu tại Ring 0.

2.2.4. Cơ chế Quarantine: Suspend tiến trình và cô lập tệp tin độc hại.

CHƯƠNG 3: GIẢI PHÁP PHỤC HỒI DỮ LIỆU

3.1. Xây dựng công cụ giải mã dữ liệu (Decrypter)

3.1.1. Ứng dụng kết quả bóc tách thuật toán và lỗ hổng sinh khóa để xây dựng logic giải mã.

3.1.2. Quy trình quét dữ liệu bị tác động và khôi phục tính toàn vẹn cho tệp tin người dùng.

3.2. Quy trình xử lý và khắc phục sự cố

3.2.1. Xây dựng kịch bản ứng phó sự cố (Incident Response) khi phát hiện dấu hiệu xâm nhập.

3.2.2. Quy trình làm sạch hệ thống và đảm bảo an toàn dữ liệu sau tấn công.

CHƯƠNG 4: KẾT QUẢ VÀ ĐÁNH GIÁ THỰC NGHIỆM

4.1. Kịch bản thực nghiệm Proof of Concept (PoC)

4.1.1. Đánh giá khả năng ngăn chặn: Chạy mã độc thực tế và kiểm chứng tính năng block của Driver.

4.1.2. Đánh giá khả năng phục hồi: Kiểm chứng hiệu quả của Decrypter trên các tệp tin bị ảnh hưởng ban đầu.

4.2. Tổng kết và Đánh giá hệ thống

4.2.1. Đánh giá hiệu năng: Tốc độ xử lý I/O, tỷ lệ file được bảo vệ và độ ổn định hệ thống (tránh BSOD).

4.2.2. Ưu điểm, hạn chế và hướng phát triển (Tích hợp trí tuệ nhân tạo trong nhận diện hành vi).

KẾT LUẬN

TÀI LIỆU THAM KHẢO

III. TÀI LIỆU THAM KHẢO ĐỂ XÂY DỰNG ĐỀ CƯƠNG

1. Microsoft Corporation, "File System Minifilter Drivers," Windows Driver documentation.
2. T. Shannon, "A Mathematical Theory of Communication," The Bell System Technical Journal.

Hà Nội, ngày tháng 01 năm 2026

CÁN BỘ HƯỚNG DẪN

(Ký, ghi rõ họ và tên)

SINH VIÊN

(Ký, ghi rõ họ và tên)